

รายงานวิชา

Computer Networks (เครือข่ายคอมพิวเตอร์)

เรื่อง การออกแบบและติดตั้งระบบเว็บไซต์ WordPress บน Microsoft Azure ด้วย Nginx, PHP-FPM และ MySQL พร้อมมาตรการรักษาความปลอดภัยเครือข่าย

จัดทำโดย

ปภาวรินท์	ผกาศรี	67160073
พิชญุตม์	บุญสุรเมธสกุล	67160076
สราวุฒิ	อ่อนระเบียบ	67160107
อินธิรา	วงษ์ทอง	67160111
สรวิศ	พุฒกลั่น	67160275
เมธา	ฉิมเล็ก	67160428

เสนอ

ผศ.ภูสิต กุลเกษม

ภาควิชาวิทยาการคอมพิวเตอร์

คณะวิทยาการสารสนเทศ มหาวิทยาลัยบูรพา

ภาคเรียนที่ 3 ปีการศึกษา 2569

คำนำ

รายงานฉบับนี้จัดทำขึ้นเพื่อเป็นส่วนหนึ่งของวิชา Computer Networks (เครือข่ายคอมพิวเตอร์) โดยมีวัตถุประสงค์เพื่อศึกษาและประยุกต์ใช้ความรู้เกี่ยวกับการออกแบบ ติดตั้ง และตรวจสอบระบบเว็บไซต์ WordPress บนแพลตฟอร์ม Microsoft Azure ซึ่งเป็นบริการคลาวด์คอมพิวตั้ง โดยใช้ Ubuntu Server 24.04.5 LTS เป็นระบบปฏิบัติการ และใช้ Nginx, PHP-FPM, WordPress และ MySQL เป็นองค์ประกอบหลักในการให้บริการเว็บไซต์

เนื้อหาในรายงานประกอบด้วยการสร้างและกำหนดค่าเครื่องเสมือนบน Microsoft Azure การติดตั้งและตั้งค่าระบบ WordPress การกำหนดชื่อโดเมนและการเชื่อมต่อผ่าน DNS, HTTP/HTTPS และ SSH ตลอดจนการตรวจสอบสถานะการทำงานของบริการต่าง ๆ นอกจากนี้ ยังศึกษาและประยุกต์ใช้มาตรการรักษาความปลอดภัยเครือข่ายทั้งในระดับคลาวด์และระบบปฏิบัติการ เช่น Azure Network Security Group, iptables, ipset และ Fail2ban รวมถึงการติดตั้งใบรับรอง TLS จาก Let's Encrypt เพื่อเพิ่มความปลอดภัยในการรับส่งข้อมูลผ่านเว็บไซต์

ผู้จัดทำหวังเป็นอย่างยิ่งว่ารายงานฉบับนี้จะเป็นประโยชน์ต่อการศึกษา และช่วยให้ผู้อ่านมีความรู้ความเข้าใจเกี่ยวกับการติดตั้งและบริหารจัดการเว็บไซต์บนระบบคลาวด์ การทำงานของบริการเครือข่าย และการกำหนดมาตรการรักษาความปลอดภัยของระบบได้อย่างเหมาะสม หากมีข้อผิดพลาดหรือข้อบกพร่องประการใด คณะผู้จัดทำขออภัยมา ณ ที่นี้

คณะผู้จัดทำ

สารบัญ

เรื่อง	หน้า
คำนำ	ก
สารบัญ	ข
สารบัญภาพ	ค
สารบัญตาราง	ง
บทที่ 1 บทนำ	1
1.1 ที่มาและความสำคัญของโครงงาน	1
1.2 วัตถุประสงค์ของโครงงาน	1
1.3 ขอบเขตของโครงงาน	2
1.4 ประโยชน์ที่คาดว่าจะได้รับ	2
1.5 วิธีดำเนินงาน	3
1.6 คำจำกัดความ	4
บทที่ 2 ทฤษฎีและเทคโนโลยีที่เกี่ยวข้อง	6
2.1 Cloud Virtual Machine และเครือข่ายเสมือน	6
2.2 DNS, IP Address และโปรโตคอลเครือข่าย	6
2.2.1 ระบบชื่อโดเมน (DNS)	6
2.2.2 โปรโตคอลและพอร์ตที่เกี่ยวข้อง	7
2.3 Nginx และ PHP-FPM	7
2.3.1 Nginx	7
2.3.2 PHP-FPM	7
2.4 WordPress และ MySQL	8
2.4.1 WordPress	8
2.4.2 MySQL	8
2.5 HTTPS, TLS และใบรับรอง Let’s Encrypt	8
2.6 มาตรการรักษาความปลอดภัยแบบหลายชั้น	9
2.6.1 Azure Network Security Group (NSG)	9
2.6.2 iptables และ ipset	9
2.6.3 SSH แบบ Key-only และ Fail2ban	9
2.6.4 สรุปมาตรการรักษาความปลอดภัยแต่ละชั้น	10

2.7 หลักการประเมินผลทางเทคนิค 12
บทที่ 3 การออกแบบและดำเนินงาน 12
3.1 ความต้องการของระบบ 12
3.2 รายละเอียดเครื่องเสมือนบนคลาวด์และซอฟต์แวร์ 13
3.3 สถาปัตยกรรมเครือข่าย 14
3.4 การกำหนด DNS และพอร์ตเครือข่าย 14
3.5 การติดตั้งและตั้งค่า Web Stack 15
3.6 การติดตั้งใบรับรองและตั้งค่า HTTPS 16
3.7 การเสริมความปลอดภัย 16
3.7.1 Azure Network Security Group (NSG) 16
3.7.2 iptables/ipset Geo-blocking 17
3.7.3 SSH Hardening และ Fail2ban 17
3.8 แผนการทดสอบระบบ 18
บทที่ 4 ผลการทดสอบและวิเคราะห์ผล 19
4.1 วิธีการประเมินผล 19
4.2 ผลการตรวจสถานะบริการหลัก 19
4.3 ผลการตรวจพอร์ตที่เปิดใช้งาน 20
4.4 ผลการตรวจ Nginx และใบรับรอง TLS 21
4.5 ผลการตรวจ NSG, iptables/ipset และ Fail2ban 22
4.5.1 Azure Network Security Group (NSG) 22
4.5.2 iptables/ipset Geo-blocking 23
4.5.3 Fail2ban SSH Jail 24
4.6 ผลการตรวจการทำงานของ WordPress 24
4.7 สรุปผลการทดสอบตามรายการ 25
4.8 ข้อจำกัดและความสอดคล้องของหลักฐาน 26
บทที่ 5 สรุปผลและข้อเสนอแนะ 27
5.1 สรุปผลการดำเนินงาน 27
5.2 ข้อจำกัดของระบบ 27
5.3 ข้อเสนอแนะเพื่อการพัฒนา 28
5.4 บทสรุปสุดท้าย 29
เอกสารอ้างอิง 29

ภาคผนวก ก รายการภาพหน้าจอหลักฐาน 31
ภาคผนวก ข คำสั่งตรวจสอบที่ใช้ 32

สารบัญรูปภาพ

ภาพที่		หน้า
3.1	ข้อมูลคุณสมบัติของเครื่องเสมือนบน Azure Portal	13
3.2	แผนภาพสถาปัตยกรรมระบบตามค่าที่โครงการรายงาน	14
3.3	การตรวจสอบ DNS ด้วย nslookup	15
3.4	กฎ Inbound Security Rules ของ Azure NSG (Papaya-nsg)	15
4.1	ผลการตรวจสอบสถานะการทำงานของบริการหลักบนเซิร์ฟเวอร์	20
4.2	ผลการตรวจสอบพอร์ตบริการเครือข่ายและสถานะ Listener ด้วยคำสั่ง ss -tulpn	21
4.3	ผลการตรวจสอบไวยากรณ์และความถูกต้องของไฟล์กำหนดค่า Nginx	22
4.4	ผลการตรวจสอบสถานะใบรับรอง SSL/TLS และการจำลองต่ออายุด้วย Certbot	22
4.5	ผลการตรวจสอบกฎการเชื่อมต่อขาเข้า (Inbound Security Rules) บน Azure NSG	23
4.6	ผลการตรวจสอบกฎความปลอดภัยบน iptables และการเปิดใช้งาน Geo-blocking ร่วมกับ IP set	23
4.7	ผลการตรวจสอบสถานะการป้องกันการโจมตีทาง SSH ด้วย Fail2ban	24
4.8	ผลการเข้าถึงหน้าเว็บไซต์ WordPress ผ่านโปรโตคอล HTTPS	25

สารบัญตาราง

ตารางที่		หน้า
1.1	คำจำกัดความของคำศัพท์ที่เกี่ยวข้อง	5
2.1	พอร์ตและโปรโตคอลที่เกี่ยวข้องกับระบบ	7
2.2	สรุปมาตรการรักษาความปลอดภัยแบบหลายชั้น	10
2.3	หลักฐานทางเทคนิคและขอบเขตของสิ่งที่ยืนยันได้	11
3.1	ความต้องการของระบบและเกณฑ์การตรวจสอบ	12
3.2	รายละเอียดเครื่องเสมือนและซอฟต์แวร์ที่ใช้ในโครงการ	13
3.3	การกำหนดพอร์ตเครือข่ายและประเด็นด้านความปลอดภัย	15
3.4	กฎ Inbound ของ NSG ชื่อ Papaya-nsg	16
3.5	การตั้งค่า SSH เพื่อเสริมความปลอดภัย	17
3.6	แผนการทดสอบระบบ	18
4.1	ผลการตรวจสถานะบริการหลัก	19
4.2	ผลการตรวจพอร์ตที่รับฟังและนัยด้านความปลอดภัย	20
4.3	ผลการตรวจ Nginx และใบรับรอง TLS	21
4.4	ผลการตรวจกฎ Inbound ของ Azure NSG	22
4.5	สรุปผลการทดสอบตามรหัสการทดสอบ	25
5.1	ข้อจำกัดของระบบและผลกระทบ	27
5.2	ข้อเสนอแนะเพื่อการพัฒนาระบบ	28
ก.1	รายการภาพหน้าจอหลักฐานที่ต้องแทรกในรายงาน	31

บทที่ 1

บทนำ

1.1 ที่มาและความสำคัญของโครงงาน

ในปัจจุบัน เว็บไซต์เป็นช่องทางสำคัญในการเผยแพร่ข้อมูลและให้บริการผ่านเครือข่ายอินเทอร์เน็ต โดยระบบจัดการเนื้อหา (Content Management System: CMS) ช่วยให้ผู้ดูแลสามารถสร้าง แก้ไข และจัดการเนื้อหาบนเว็บไซต์ได้อย่างสะดวก โดยไม่จำเป็นต้องเขียนโปรแกรมทุกส่วนด้วยตนเอง WordPress เป็นหนึ่งในระบบจัดการเนื้อหาที่ได้รับความนิยม เนื่องจากมีความยืดหยุ่นและสามารถนำไปติดตั้งบนเซิร์ฟเวอร์ที่มีการเชื่อมต่อเครือข่ายได้หลากหลายรูปแบบ

โครงงานเรื่อง **การติดตั้ง** WordPress **บน** Microsoft Azure **พร้อมระบบรักษาความปลอดภัยเครือข่าย** จัดทำขึ้นเพื่อศึกษาและประยุกต์ใช้ความรู้ด้านเครือข่ายคอมพิวเตอร์ โดยนำ WordPress มาติดตั้งบนเครื่องเสมือน (Virtual Machine: VM) ของ Microsoft Azure ใช้ Ubuntu Server 24.04.5 LTS เป็นระบบปฏิบัติการ และใช้ Nginx, PHP-FPM และ MySQL เป็นองค์ประกอบหลักในการให้บริการเว็บไซต์ เพื่อศึกษาการทำงานร่วมกันของระบบคลาวด์ เว็บเซิร์ฟเวอร์ ตัวประมวลผล PHP และระบบฐานข้อมูล

นอกจากนี้ โครงงานยังให้ความสำคัญกับการทำงานของเครือข่าย ตั้งแต่การแปลงชื่อโดเมนเป็นหมายเลข IP Address การรับส่งข้อมูลผ่านโพรโทคอล HTTP/HTTPS การเชื่อมต่อเพื่อจัดการเซิร์ฟเวอร์ผ่าน SSH ตลอดจนการกำหนดกฎควบคุมการรับส่งข้อมูลด้วย Azure Network Security Group (NSG) และไฟร์วอลล์ภายในระบบปฏิบัติการ รวมถึงการใช้ Fail2ban เพื่อตรวจจับและป้องกันความพยายามเข้าสู่ระบบที่ผิดปกติ

ดังนั้น โครงงานนี้จึงเป็นแนวทางในการเรียนรู้การติดตั้งและบริหารจัดการเว็บไซต์บนระบบคลาวด์ ควบคู่กับการตรวจสอบการทำงานของบริการเครือข่ายและการประยุกต์ใช้มาตรการรักษาความปลอดภัย เพื่อให้สามารถนำความรู้ไปประยุกต์ใช้กับการดูแลระบบเว็บไซต์และเซิร์ฟเวอร์ในสถานการณ์จริงได้อย่างเหมาะสม

1.2 วัตถุประสงค์ของโครงงาน

1. เพื่อออกแบบและติดตั้งระบบเว็บไซต์ WordPress บนเครื่องเสมือน Microsoft Azure โดยใช้ Ubuntu Server 24.04.5 LTS เป็นระบบปฏิบัติการ

2. เพื่อศึกษาการทำงานร่วมกันของ Nginx, PHP-FPM, WordPress และ MySQL ในการให้บริการเว็บไซต์
3. เพื่อศึกษาการสื่อสารผ่าน DNS, HTTP/HTTPS และ SSH รวมถึงตรวจสอบพอร์ตที่ใช้ในการให้บริการของระบบ
4. เพื่อประยุกต์ใช้มาตรการรักษาความปลอดภัยเครือข่าย ได้แก่ Azure Network Security Group, iptables, ipset และ Fail2ban รวมถึงการรักษาความปลอดภัยในการเข้าถึงเซิร์ฟเวอร์ผ่าน SSH ตามการตั้งค่าที่ใช้งานจริง
5. เพื่อทดสอบและบันทึกผลการทำงานของระบบ พร้อมจัดเก็บภาพหน้าจอและหลักฐานที่เกี่ยวข้องอย่างเป็นระบบ

1.3 ขอบเขตของโครงงาน

โครงงานนี้ครอบคลุมการติดตั้งและกำหนดค่าระบบเว็บไซต์ WordPress บนเครื่องเสมือน Microsoft Azure โดยแบ่งขอบเขตการศึกษาออกเป็นด้านต่าง ๆ ดังนี้

1. **ด้านโครงสร้างพื้นฐานคลาวด์**: การสร้างและกำหนดค่าเครื่องเสมือนบน Microsoft Azure รวมถึงระบบปฏิบัติการ Ubuntu Server 24.04.5 LTS
2. **ด้านบริการเว็บไซต์**: การติดตั้งและกำหนดค่า Nginx, PHP-FPM, WordPress และ MySQL เพื่อให้สามารถให้บริการเว็บไซต์ได้
3. **ด้านเครือข่าย**: การกำหนดชื่อโดเมนและการเชื่อมต่อผ่าน DNS, HTTP/HTTPS และ SSH รวมถึงการตรวจสอบพอร์ตที่เกี่ยวข้องกับการให้บริการ
4. **ด้านความปลอดภัย**: การกำหนดกฎ Azure Network Security Group การใช้ iptables และ ipset เพื่อควบคุมทราฟฟิกเครือข่าย การใช้ Fail2ban เพื่อตรวจจับความพยายามเข้าสู่ระบบ SSH ที่ผิดปกติ และการใช้ใบรับรอง TLS เพื่อเข้ารหัสการรับส่งข้อมูลผ่าน HTTPS
5. **ด้านการทดสอบและตรวจสอบ**: การตรวจสอบสถานะบริการ การตรวจสอบไวยากรณ์การตั้งค่า Nginx การตรวจสอบพอร์ตและการเชื่อมต่อ ตลอดจนการบันทึกผลการทดสอบและจัดเก็บหลักฐานประกอบรายงาน

ทั้งนี้ ผลการดำเนินงานจะนำเสนอเฉพาะข้อมูลที่มีหลักฐานหรือผลการตรวจสอบรองรับ ส่วนการทดสอบประสิทธิภาพเชิงปริมาณ การสำรองและกู้คืนข้อมูลอย่างครบวงจร และการจัดทำระบบความพร้อมใช้งานสูง (High Availability) ไม่ถือเป็นขอบเขตหลักของโครงงานฉบับนี้

1.4 ประโยชน์ที่คาดว่าจะได้รับ

1. มีความรู้ความเข้าใจเกี่ยวกับการติดตั้งและบริหารจัดการเว็บไซต์ WordPress บนแพลตฟอร์ม Microsoft Azure
2. เข้าใจการทำงานร่วมกันของเว็บเซิร์ฟเวอร์ ตัวประมวลผล PHP และระบบฐานข้อมูล
3. เข้าใจเส้นทางการรับส่งข้อมูลผ่าน DNS, HTTP/HTTPS และ SSH รวมถึงบทบาทของพอร์ตเครือข่ายในการให้บริการ
4. สามารถตรวจสอบสถานะบริการและพอร์ตเครือข่ายเบื้องต้น เพื่อใช้วิเคราะห์ปัญหาการเชื่อมต่อของระบบ
5. เข้าใจความแตกต่างระหว่างการควบคุมทราฟฟิกด้วย Azure Network Security Group และการกรองทราฟฟิกด้วยไฟร์วอลล์ภายในเครื่องเสมือน
6. มีแนวทางในการประยุกต์ใช้มาตรการรักษาความปลอดภัยเครือข่าย เพื่อช่วยลดความเสี่ยงจากการเข้าถึงระบบโดยไม่ได้รับอนุญาต

1.5 วิธีดำเนินงาน

การดำเนินโครงงานแบ่งออกเป็นขั้นตอนดังต่อไปนี้

1. **วางแผนและเตรียมระบบ**: กำหนดทรัพยากรที่ใช้บน Microsoft Azure สร้างเครื่องเสมือน และกำหนดชื่อโดเมนให้ชี้ไปยัง Public IP Address ของเครื่องเสมือน
2. **ติดตั้งบริการเว็บไซต์**: ติดตั้งและกำหนดค่า Nginx, PHP-FPM, WordPress และ MySQL เพื่อให้ระบบสามารถให้บริการเว็บไซต์ได้
3. **กำหนดค่าการเชื่อมต่อเครือข่าย**: ตั้งค่าการเชื่อมต่อผ่าน DNS, HTTP/HTTPS และ SSH พร้อมตรวจสอบการเข้าถึงบริการและพอร์ตที่เกี่ยวข้อง
4. **ติดตั้งและกำหนดค่าความปลอดภัย**: กำหนดกฎ Azure Network Security Group ใช้ iptables และ ipset ตามนโยบายการกรองทราฟฟิกที่กำหนดค่าไว้ ติดตั้งใบรับรอง TLS จาก Let's Encrypt และกำหนดค่า Fail2ban เพื่อช่วยป้องกันความพยายามเข้าสู่ระบบที่ผิดปกติ
5. **ทดสอบและตรวจสอบระบบ**: ตรวจสอบสถานะบริการ ทดสอบการตั้งค่า Nginx ตรวจสอบพอร์ตที่เปิดรับการเชื่อมต่อ และตรวจสอบใบรับรอง TLS
6. **บันทึกและสรุปผล**: รวบรวมผลการตรวจสอบ ภาพหน้าจอ และหลักฐานที่เกี่ยวข้อง พร้อมวิเคราะห์ผลการดำเนินงานและจัดทำรายงานฉบับสมบูรณ์

1.6 **คำจำกัดความ**

คำศัพท์	ความหมาย
Microsoft Azure	แพลตฟอร์มคลาวด์คอมพิวติ้งที่ให้บริการทรัพยากรประมวลผลและระบบเครือข่ายผ่านอินเทอร์เน็ต
Virtual Machine (VM)	เครื่องเสมือนที่ทำงานบนโครงสร้างพื้นฐานคลาวด์ โดยสามารถติดตั้งระบบปฏิบัติการและซอฟต์แวร์ได้
Ubuntu Server	ระบบปฏิบัติการ Linux ที่ออกแบบมาสำหรับการให้บริการและบริหารจัดการระบบเซิร์ฟเวอร์
DNS (Domain Name System)	ระบบที่ใช้แปลงชื่อโดเมนให้เป็นข้อมูลที่ใช้ระบุปลายทาง เช่น IP Address
IP Address	หมายเลขที่ใช้ระบุอุปกรณ์หรือจุดเชื่อมต่อบนเครือข่าย IP
Nginx	เว็บเซิร์ฟเวอร์ที่รับคำขอจากผู้ใช้และส่งข้อมูลเว็บไซต์กลับไปยังผู้ร้องขอ
PHP-FPM	ระบบจัดการโปรเซส PHP ที่ช่วยประมวลผลคำขอจากเว็บเซิร์ฟเวอร์ผ่าน FastCGI
WordPress	ระบบจัดการเนื้อหา (CMS) สำหรับสร้างและบริหารจัดการเว็บไซต์
MySQL	ระบบจัดการฐานข้อมูลเชิงสัมพันธ์ที่ใช้จัดเก็บข้อมูลของเว็บไซต์
HTTP/HTTPS	โพรโทคอลสำหรับรับส่งข้อมูลบนเว็บ โดย HTTPS ใช้ TLS เพื่อเข้ารหัสการสื่อสาร
SSH (Secure Shell)	โพรโทคอลสำหรับเชื่อมต่อและบริหารจัดการระบบระยะไกลอย่างปลอดภัย
Azure Network Security Group (NSG)	กลไกควบคุมการรับส่งข้อมูลเครือข่ายของ Azure ตามกฎอนุญาตหรือปฏิเสธทราฟฟิก
iptables	เครื่องมือสำหรับกำหนดกฎกรองและควบคุมแพ็กเก็ตเครือข่ายในระบบ Linux
ipset	เครื่องมือสำหรับจัดเก็บและจัดการชุดที่อยู่ IP หรือข้อมูลเครือข่าย เพื่อนำไปใช้ร่วมกับกฎไฟร์วอลล์

TLS Certificate	ใบรับรองดิจิทัลที่ใช้ยืนยันตัวตนของเว็บไซต์และสนับสนุนการสร้างการเชื่อมต่อที่เข้ารหัสผ่าน TLS
Fail2ban	เครื่องมือที่ตรวจสอบบันทึกเหตุการณ์และสามารถบล็อกแหล่งที่มาของการเชื่อมต่อที่มีพฤติกรรมผิดปกติตามกฎที่กำหนด
Firewall	ระบบหรือกลไกที่ใช้ควบคุมการรับส่งข้อมูลเครือข่ายตามนโยบายความปลอดภัย
Geo-blocking	การจำกัดหรืออนุญาตการเชื่อมต่อโดยอ้างอิงข้อมูลตำแหน่งทางภูมิศาสตร์ของ IP Address ซึ่งขึ้นอยู่กับชุดข้อมูลและกฎที่นำมาใช้

ตารางที่ 1.1 พอร์ตและโปรโตคอลที่เกี่ยวข้องกับระบบ

บทที่ 2

ทฤษฎีและเทคโนโลยีที่เกี่ยวข้อง

บทนี้อธิบายทฤษฎีและเทคโนโลยีที่เกี่ยวข้องกับการออกแบบ การติดตั้ง และการรักษาความปลอดภัยของเว็บเซิร์ฟเวอร์บนคลาวด์ ประกอบด้วยเครื่องเสมือนบนคลาวด์ ระบบชื่อโดเมน โปรโตคอลเครือข่าย ซอฟต์แวร์เว็บเซิร์ฟเวอร์ ระบบจัดการเนื้อหา การเข้ารหัสการสื่อสาร และมาตรการรักษาความปลอดภัยแบบหลายชั้น รวมถึงหลักการประเมินผลทางเทคนิคที่ใช้ในการตรวจสอบระบบ

2.1 Cloud Virtual Machine และเครือข่ายเสมือน

เครื่องเสมือนบนคลาวด์ (Cloud Virtual Machine) เป็นทรัพยากรคอมพิวเตอร์ที่จัดสรร CPU หน่วยความจำ ดิสก์ และอินเทอร์เฟซเครือข่ายให้แก่ระบบปฏิบัติการ ผู้ดูแลระบบสามารถติดตั้งบริการและกำหนดค่าเครือข่ายได้เช่นเดียวกับเซิร์ฟเวอร์ทั่วไป โครงการนี้ใช้เครื่องเสมือนของ Microsoft Azure ชื่อ Papaya ใน Region Japan East โดยมี Public IP สำหรับรับการเชื่อมต่อจากภายนอก และ Private IP สำหรับใช้งานภายในเครือข่ายเสมือนของ Azure

การแยก Public IP และ Private IP ทำให้บริการมีจุดเชื่อมต่อกับอินเทอร์เน็ตได้ ขณะที่การสื่อสารภายในเครื่องเสมือนหรือภายใน Virtual Network (VNet) สามารถใช้ที่อยู่ส่วนตัวตามการออกแบบได้ อย่างไรก็ตาม การที่เครื่องเสมือนมี Public IP มิได้หมายความว่าควรเปิดทุกพอร์ตให้เข้าถึงได้ การเปิดพอร์ตจึงต้องสอดคล้องกับความต้องการของบริการและนโยบายความปลอดภัย

2.2 DNS, IP Address และโปรโตคอลเครือข่าย

2.2.1 ระบบชื่อโดเมน (DNS)

Domain Name System (DNS) ทำหน้าที่แปลงชื่อโดเมนที่มนุษย์จดจำได้ให้เป็น IP Address โดยโครงงานนี้ใช้ชื่อโดเมน papayapogpog.duckdns.org และตรวจสอบด้วยคำสั่ง nslookup ตามภาพหลักฐานที่ได้รับ การตรวจสอบ DNS ควรบันทึกชื่อที่สอบถาม เซิร์ฟเวอร์ DNS ที่ตอบกลับ และ IP Address ที่ได้รับ ณ เวลาทดสอบ เนื่องจากค่าดังกล่าวอาจเปลี่ยนแปลงได้

2.2.2 โปรโตคอลและพอร์ตที่เกี่ยวข้อง

HyperText Transfer Protocol (HTTP) ใช้แลกเปลี่ยนคำขอและผลตอบกลับของเว็บ ส่วน HTTPS คือ HTTP ที่ทำงานบนการเชื่อมต่อซึ่งเข้ารหัสด้วย Transport Layer Security (TLS) เพื่อช่วยปกป้องความลับและความสมบูรณ์ของข้อมูลระหว่างการส่ง รายงานนี้เกี่ยวข้องกับพอร์ตหลักตามตารางที่ 2.1

พอร์ต	โปรโตคอล/บริการ	หน้าที่	สถานะการเข้าถึงในระบบนี้
TCP/80	HTTP	ให้บริการเว็บแบบไม่เข้ารหัส	เปิดรับจากภายนอกตามกฎ NSG
TCP/443	HTTPS	ให้บริการเว็บแบบเข้ารหัสด้วย TLS	เปิดรับจากภายนอกตามกฎ NSG
TCP/22	SSH	บริหารจัดการเซิร์ฟเวอร์จากระยะไกล	เปิดรับตามกฎ NSG (Source เป็น Any)
TCP/3306	MySQL	พอร์ตเริ่มต้นของฐานข้อมูล MySQL	ผูกกับ 127.0.0.1 เท่านั้น

ตารางที่ 2.1 พอร์ตและโปรโตคอลที่เกี่ยวข้องกับระบบ

2.3 Nginx และ PHP-FPM

2.3.1 Nginx

Nginx ทำหน้าที่รับคำขอจากเบราว์เซอร์ ให้บริการไฟล์สถิติตามการตั้งค่า และส่งต่อคำขอที่ต้องประมวลผลด้วย PHP ไปยัง FastCGI server โดยใช้คำสั่ง fastcgi_pass ซึ่งสามารถระบุปลายทางเป็น TCP socket หรือ Unix-domain socket ได้ ในระบบนี้ข้อมูลที่ได้รับระบุว่า PHP-FPM 8.3 ทำงานผ่าน Unix socket จึงไม่จำเป็นต้องเปิดพอร์ต TCP ของ PHP-FPM สู่อินเทอร์เน็ต

2.3.2 PHP-FPM

PHP FastCGI Process Manager (PHP-FPM) ทำหน้าที่จัดการโปรเซสสำหรับประมวลผล PHP โดย WordPress ใช้ PHP สร้างหน้าเว็บแบบไดนามิกและติดต่อกับฐานข้อมูล ข้อมูลสถานะที่ได้รับระบุว่า PHP-FPM ทำงานอยู่ และมีการประมวลผลสะสม

2,912 requests ณ เวลาที่บันทึกผล โดยมี active processes จำนวน 0 และ idle processes จำนวน 3 ตัวเลขดังกล่าวเป็นภาพสถานะ ณ ขณะใดขณะหนึ่ง มิใช่ผลการทดสอบสมรรถนะ (benchmark) ของ throughput หรือจำนวนผู้ใช้พร้อมกันที่ระบบรองรับได้

2.4 WordPress และ MySQL

2.4.1 WordPress

WordPress เป็นระบบจัดการเนื้อหา (Content Management System: CMS) สำหรับจัดการหน้าเว็บ บทความ เมนู และสื่อประกอบ โดยใช้ PHP ประมวลผลคำขอและใช้ฐานข้อมูลเก็บเนื้อหาและการตั้งค่าที่เกี่ยวข้อง ข้อกำหนดที่เผยแพร่โดย WordPress.org แนะนำให้ใช้ PHP 8.3 ขึ้นไป MySQL 8.0 ขึ้นไปหรือ MariaDB รุ่นที่รองรับ และ HTTPS เวอร์ชันที่ใช้ในโครงการคือ PHP 8.3.6 และ MySQL 8.0.46

2.4.2 MySQL

MySQL ทำหน้าที่เก็บข้อมูลของเว็บไซต์ และสามารถกำหนดที่อยู่สำหรับรับการเชื่อมต่อด้วยตัวแปร bind_address ได้ [5] หลักฐานที่ได้รับแสดงว่าระบบรับการเชื่อมต่อ (listen) ที่ 127.0.0.1:3306 ซึ่งหมายถึงการรับ TCP connection ผ่าน loopback address ของเครื่องเดียวกัน ช่วยลดการเปิดเผยฐานข้อมูลต่อเครือข่ายภายนอก อย่างไรก็ตาม ยังควรตรวจสอบไฟร์วอลล์และสิทธิ์ของบัญชีผู้ใช้ฐานข้อมูลประกอบกัน

2.5 HTTPS, TLS และใบรับรอง Let's Encrypt

ใบรับรองดิจิทัล TLS ช่วยให้เบราว์เซอร์ตรวจสอบตัวตนของปลายทางและสร้างช่องทางสื่อสารที่เข้ารหัสกับเว็บไซต์ได้ Certbot เป็นเครื่องมือสำหรับขอและติดตั้งใบรับรอง รวมถึงทดสอบการต่ออายุด้วยคำสั่ง renew --dry-run โครงการนี้ใช้ใบรับรอง Let's Encrypt ชนิด ECDSA สำหรับโดเมน papayapogpog.duckdns.org และตรวจสอบพบว่ามีวันหมดอายุคือ 21 มกราคม พ.ศ. 2570 (ค.ศ. 2027)

การทดสอบ renew --dry-run ที่สำเร็จเป็นหลักฐานว่ากระบวนการจำลองการต่ออายุผ่านในช่วงเวลาทดสอบ แต่มิได้รับประกันว่าการต่ออายุในอนาคตจะสำเร็จในทุกกรณี โดยเฉพาะเมื่อมีนโยบาย Geo-

blocking ที่อาจส่งผลต่อการเข้าถึงของระบบตรวจสอบใบรับรอง จึงควรติดตามผลการต่ออายุจริงและบันทึกผลการตรวจสอบเป็นรอบ ๆ

2.6 **มาตรการรักษาความปลอดภัยแบบหลายชั้น**

2.6.1 Azure Network Security Group (NSG)

NSG ใช้กฎที่เรียงตามลำดับความสำคัญ (priority) เพื่ออนุญาตหรือปฏิเสธทราฟฟิกตามเงื่อนไข ได้แก่ แหล่งที่มา ปลายทาง โปรโตคอล และพอร์ต โดย Azure จะใช้กฎที่ตรงกับเงื่อนไขตามลำดับ และมีกฎปฏิเสธทราฟฟิกขาเข้าโดยปริยายสำหรับทราฟฟิกที่ไม่มีกฎแบบกำหนดเอง (custom rule) อนุญาต [3] ผลการตรวจสอบระบุว่ากฎของพอร์ต 80, 443 และ 22 กำหนด Source เป็น Any จึงควรพิจารณาว่านโยบายดังกล่าวเหมาะสมกับความต้องการหรือไม่ โดยเฉพาะ SSH ซึ่งควรจำกัดแหล่งที่มาให้เป็น IP ของผู้ดูแลระบบเมื่อสามารถทำได้

2.6.2 iptables และ ipset

iptables ใช้กำหนดกฎกรองแพ็กเก็ตในระบบปฏิบัติการ ส่วน ipset ใช้จัดเก็บชุดของ IP Address เพื่อให้กฎอ้างอิงรายการขนาดใหญ่ได้สะดวก ข้อมูลล่าสุดจากผู้จัดทำระบุว่าใช้ชุดข้อมูลชื่อ thailand เพื่ออนุญาตทราฟฟิกเว็บจาก IP ที่อยู่ในชุดดังกล่าว และ DROP ทราฟฟิก TCP/80 และ TCP/443 เมื่อ IP ต้นทางไม่อยู่ในชุด ทั้งนี้ ผลลัพธ์ดังกล่าวขึ้นอยู่กับการเรียงลำดับกฎที่ถูกต้องและความเป็นปัจจุบันของข้อมูล IP set

2.6.3 SSH แบบ Key-only และ Fail2ban

Secure Shell (SSH) ใช้บริหารจัดการเซิร์ฟเวอร์จากระยะไกล โครงการนี้ปิดการล็อกอินด้วยบัญชี root (Root Login) และการยืนยันตัวตนด้วยรหัสผ่าน (Password Authentication) พร้อมใช้การยืนยันตัวตนด้วยกุญแจสาธารณะ (Public-Key Authentication) ชนิด Ed25519 การตั้งค่าแบบ key-only ช่วยลดการพึ่งพารหัสผ่านที่อาจถูกคาดเดาได้ แต่ยังต้องควบคุมการเก็บรักษา Private Key และกำหนดแหล่งที่มาที่อนุญาตในระดับ NSG ตามความเหมาะสม

Fail2ban ตรวจสอบไฟล์บันทึก (log) และใช้ jail เพื่อกำหนดการตอบสนองต่อรูปแบบความล้มเหลว เช่น การพยายามล็อกอิน SSH ซ้ำหลายครั้ง การทำงานจริงควร

ตรวจสอบจากสถานะของ jail และไฟล์ configuration ที่ใช้งาน [6] จำนวน failed attempts และ banned IP ที่รายงานเป็นตัวชี้วัดจากช่วงเวลาตรวจสอบหนึ่งเท่านั้น มิได้พิสูจน์ว่าทุกความพยายามมาจากผู้โจมตีรายเดียวกัน หรือว่าระบบไม่เคยถูกบุกรุก

2.6.4 สรุปมาตรการรักษาความปลอดภัยแต่ละชั้น

ชั้นการป้องกัน	เทคโนโลยี	หน้าที่หลัก	ข้อควรพิจารณา
เครือข่ายคลาวด์	Azure NSG	กรองทราฟฟิกตามแหล่งที่มา ปลายทาง โปรโตคอล และพอร์ต	Source ของพอร์ต 80, 443 และ 22 เป็น Any ควรจำกัด SSH ให้เหลือเฉพาะ IP ผู้ดูแล
ระบบปฏิบัติการ	iptables และ ipset	อนุญาตเฉพาะ IP ในชุด thailand สำหรับ TCP/80 และ TCP/443	ต้องเรียงลำดับกฎถูกต้องและปรับปรุงข้อมูล IP set ให้เป็นปัจจุบัน
การยืนยันตัวตน	SSH Key-only (Ed25519)	ปิด Root Login และ Password Authentication	ต้องรักษา Private Key อย่างปลอดภัย
การตอบสนองต่อภัยคุกคาม	Fail2ban	ตรวจจับและห้าม IP ที่ล็อกอินล้มเหลวซ้ำ	ตัวเลขเป็นผลจากช่วงเวลาตรวจสอบหนึ่งเท่านั้น
ฐานข้อมูล	MySQL bind 127.0.0.1	จำกัดการรับการเชื่อมต่อเฉพาะภายในเครื่อง	ควรตรวจสอบสิทธิ์บัญชีฐานข้อมูลควบคู่กัน
การเข้ารหัสการสื่อสาร	TLS (Let's Encrypt, ECDSA)	เข้ารหัสข้อมูลระหว่างเบราว์เซอร์กับเซิร์ฟเวอร์	Geo-blocking อาจกระทบการต่ออายุใบรับรอง

ตารางที่ 2.2 สรุปมาตรการรักษาความปลอดภัยแบบหลายชั้น

2.7 หลักการประเมินผลทางเทคนิค

การตรวจสอบโครงงานใช้หลักฐานที่สามารถทำซ้ำได้ ตามตารางที่ 2.3 โดยหลักฐานแต่ละประเภทตอบคำถามเฉพาะด้าน จึงไม่ควรนำผลการตรวจสอบด้านหนึ่งไปสรุปแทนอีกด้านหนึ่ง ตัวอย่างเช่น คำสั่ง nginx -t ตรวจสอบเฉพาะไวยากรณ์ (syntax) ของไฟล์ configuration มิได้ยืนยันว่า WordPress เชื่อมต่อฐานข้อมูลสำเร็จ และการเห็นเว็บไซต์ในเบราว์เซอร์เพียงอย่างเดียวไม่สามารถยืนยันได้ว่าการบล็อกตามประเทศทำงานตามนโยบาย

หลักฐาน	สิ่งที่ตรวจสอบได้	สิ่งที่ไม่สามารถสรุปได้
สถานะ systemd	บริการทำงานอยู่หรือไม่	บริการทำงานถูกต้องตามหน้าที่
ss -tulpn	พอร์ตและที่อยู่ที่รับการเชื่อมต่อ	ไฟร์วอลล์อนุญาตหรือปฏิเสธการเข้าถึง
nginx -t	ไวยากรณ์ของไฟล์ configuration	WordPress เชื่อมต่อฐานข้อมูลสำเร็จ
Certbot (certificates, renew --dry-run)	ใบรับรองที่ติดตั้งและผลจำลองการต่ออายุ	การต่ออายุจริงในอนาคตจะสำเร็จเสมอ
กฎ NSG	นโยบายกรองทราฟฟิกระดับเครือข่ายคลาวด์	นโยบายระดับระบบปฏิบัติการ
กฎ iptables/ipset	การกรองทราฟฟิกระดับระบบปฏิบัติการ	ความถูกต้องของข้อมูล IP set ตามจริง
สถานะ Fail2ban	จำนวนความล้มเหลวและ IP ที่ถูกห้าม	ที่มาของผู้โจมตีหรือการไม่มีการบุกรุก

ตารางที่ 2.3 หลักฐานทางเทคนิคและขอบเขตของสิ่งที่ยืนยันได้

บทที่ 3

การออกแบบและดำเนินงาน

บทนี้อธิบายการออกแบบและการดำเนินงานของระบบเว็บเซิร์ฟเวอร์ WordPress บนเครื่องเสมือนของ Microsoft Azure ประกอบด้วยความต้องการของระบบ รายละเอียดของเครื่องเสมือนและซอฟต์แวร์ สถาปัตยกรรมเครือข่าย การกำหนด DNS และพอร์ต การติดตั้งและตั้งค่า Web Stack การติดตั้งใบรับรอง การเสริมความปลอดภัย และแผนการทดสอบระบบ

3.1 ความต้องการของระบบ

ระบบต้องให้ผู้ใช้เข้าถึงหน้าเว็บไซต์ WordPress ผ่านชื่อโดเมนโดยใช้ HTTPS ผู้ดูแลระบบต้องสามารถเข้าถึงเครื่องเสมือนผ่าน SSH ด้วยวิธีที่กำหนด และฐานข้อมูลต้องไม่เปิดให้เชื่อมต่อโดยตรงจากอินเทอร์เน็ต นอกจากนี้ ระบบต้องมีกฎกรองทราฟฟิกทั้งใน Azure และที่ระดับระบบปฏิบัติการ พร้อมเครื่องมือช่วยตอบสนองต่อความพยายามเข้าสู่ระบบ SSH ที่ผิดพลาด โดยสรุปความต้องการไว้ในตารางที่ 3.1

รหัส	ความต้องการ	เกณฑ์การตรวจสอบ
REQ-01	ให้บริการเว็บไซต์ WordPress ผ่านชื่อโดเมน	DNS ชี้ไปยัง Public IP และเปิดหน้าเว็บได้ผ่าน HTTPS
REQ-02	ให้บริการ HTTP/HTTPS ด้วย Nginx	พอร์ต 80 และ 443 มี listener และ Nginx ผ่านการตรวจ syntax
REQ-03	ประมวลผล PHP ผ่าน PHP-FPM	PHP-FPM อยู่ในสถานะ active และ Nginx ส่งคำขอ PHP ผ่าน Unix socket
REQ-04	เก็บข้อมูลเว็บไซต์ใน MySQL	MySQL อยู่ในสถานะ active และ listen ที่ 127.0.0.1:3306
REQ-05	จำกัดวิธีการดูแลระบบ	SSH แบบ key-only และไม่อนุญาต Root Login รวมถึง Password Login
REQ-06	กรองทราฟฟิกเครือข่ายและตรวจจับความพยายามเข้าสู่ระบบ SSH	ตรวจสอบ NSG, iptables/ipset และ Fail2ban ได้
REQ-07	รองรับ HTTPS และการต่ออายุใบรับรอง	ใบรับรองตรงกับโดเมน และ Certbot dry-run ผ่าน

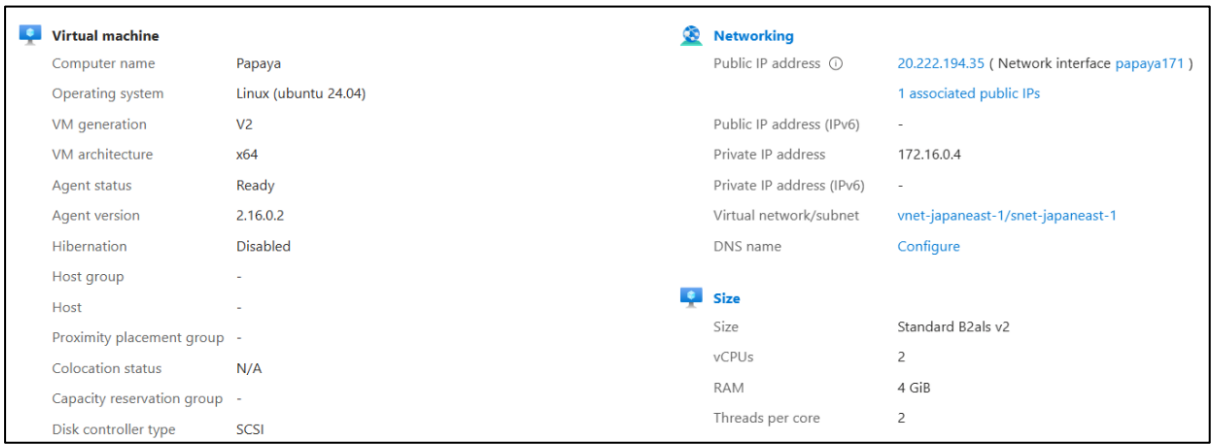
ตารางที่ 3.1 ความต้องการของระบบและเกณฑ์การตรวจสอบ

3.2 รายละเอียดเครื่องเสมือนบนคลาวด์และซอฟต์แวร์

รายละเอียดของเครื่องเสมือนและซอฟต์แวร์ที่บันทึกจากโครงการแสดงไว้ในตารางที่ 3.2

รายการ	ค่าที่บันทึกจากโครงการ
ผู้ให้บริการ / เครื่องเสมือน	Microsoft Azure / Papaya
Region	Japan East
ขนาดเครื่องเสมือน	Standard_B2als_v2
CPU / หน่วยความจำ	2 vCPU / 4 GiB RAM
พื้นที่จัดเก็บ	30 GiB, Standard SSD LRS
Public IP / Private IP	20.222.194.35 / 172.16.0.4
ระบบปฏิบัติการ	Ubuntu Server 24.04.5 LTS (Noble)
ชื่อโดเมน	papayapogpog.duckdns.org
Nginx / PHP	Nginx 1.24.0 / PHP 8.3.6
PHP-FPM	PHP 8.3 FPM (Active: running)
ฐานข้อมูล	MySQL 8.0.46
CMS / ธีม	WordPress 7.1.3 / Twenty Twenty-Five
ใบรับรอง	Let's Encrypt ชนิด ECDSA หมดอายุ 21 มกราคม พ.ศ. 2570 (ค.ศ. 2027)

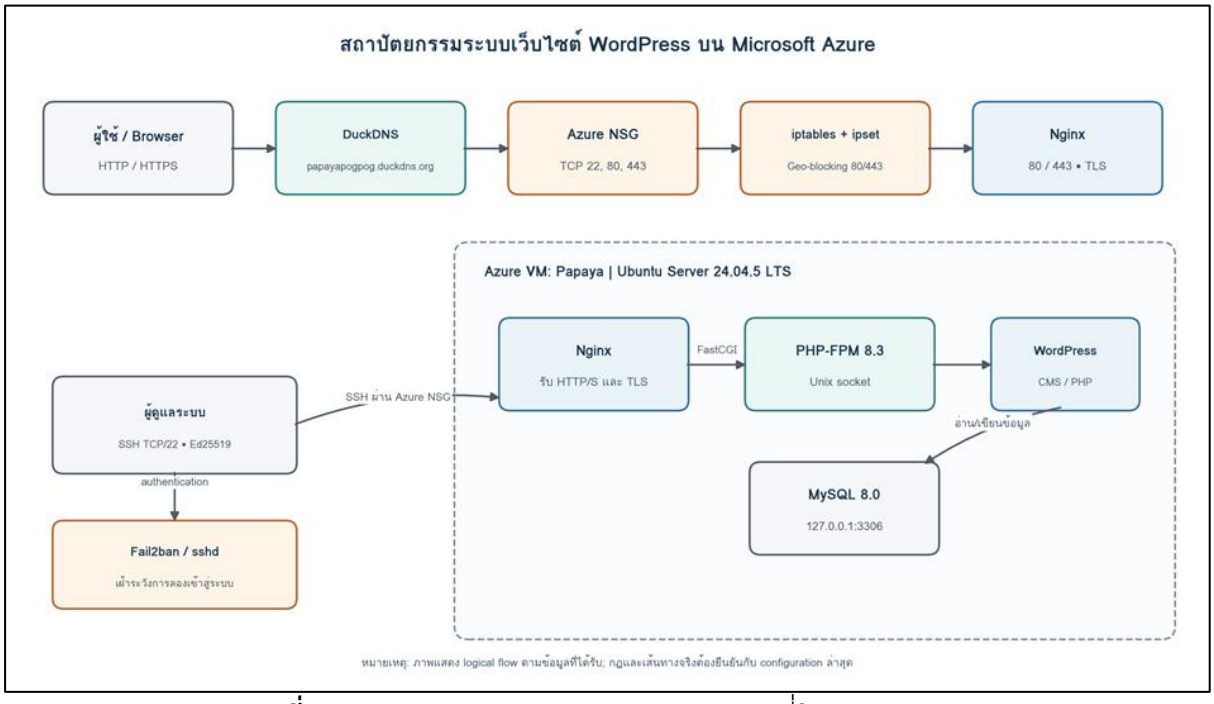
ตารางที่ 3.2 รายละเอียดเครื่องเสมือนและซอฟต์แวร์ที่ใช้ในโครงการ



ภาพที่ 3.1 ข้อมูลคุณสมบัติของเครื่องเสมือนบน Azure Portal

3.3 สถาปัตยกรรมเครือข่าย

การทำงานหลักของระบบเริ่มจากเบราว์เซอร์ของผู้ใช้สอบถาม DNS เพื่อหาที่อยู่ของโดเมน จากนั้นการเชื่อมต่อจะเข้าสู่เครื่องเสมือนบน Azure ผ่าน NSG และไฟร์วอลล์ระดับระบบปฏิบัติการ ก่อนถึง Nginx ที่รับพอร์ต 80 และ 443 เมื่อคำขอต้องประมวลผลด้วย PHP, Nginx จะส่งต่อไปยัง PHP-FPM ผ่าน Unix socket และ WordPress ใช้ MySQL ซึ่งรับการเชื่อมต่อผ่าน 127.0.0.1:3306 ตามข้อมูลที่ได้รับ



ภาพที่ 3.2 แผนภาพสถาปัตยกรรมระบบตามค่าที่โครงการรายงาน

เส้นทางบริหารจัดการแยกเป็นอีกเส้นทางหนึ่ง โดยผู้ดูแลระบบเชื่อมต่อผ่าน SSH (TCP/22) และเข้าสู่บัญชีผู้ใช้ที่ได้รับอนุญาตด้วยกุญแจ ตามการออกแบบนี้ ระบบไม่ควรเปิดพอร์ต MySQL จากอินเทอร์เน็ต เพื่อใช้จัดการฐานข้อมูลจากระยะไกล

3.4 การกำหนด DNS และพอร์ตเครือข่าย

โดเมนของโครงการคือ papayapogpog.duckdns.org โดยข้อมูลก่อนหน้าระบุ A record ชี้ไปยัง 20.222.194.35 การตรวจสอบในปัจจุบันควรเรียกใช้คำสั่ง nslookup อีกครั้ง เนื่องจากผล DNS เป็นข้อมูล ณ เวลาที่ตรวจสอบเท่านั้น การกำหนดพอร์ตจำแนกตามหน้าที่ดังตารางที่ 3.3

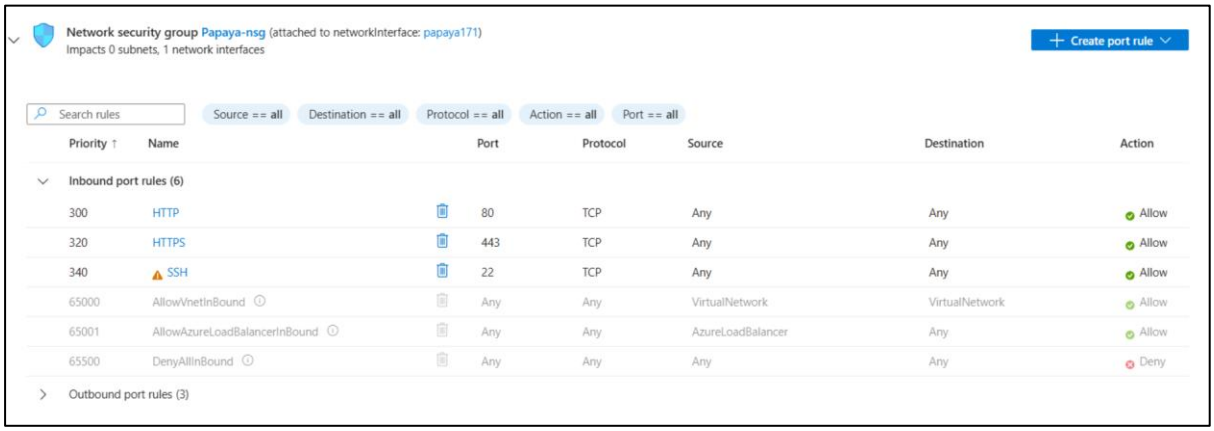
พอร์ต	บริการ	การตั้งค่าที่รายงาน	ประเด็นด้านความปลอดภัย
TCP/22	SSH (sshd)	0.0.0.0:22 และ [::]:22	NSG กำหนด Source เป็น Any ใช้ key-only และ Fail2ban ควรจำกัด Source IP
TCP/80	HTTP (Nginx)	0.0.0.0:80	NSG อนุญาตจาก Any และมีนโยบาย Geo-blocking ด้วย iptables/ipset
TCP/443	HTTPS (Nginx)	0.0.0.0:443	NSG อนุญาตจาก Any ใช้ TLS และมีนโยบาย Geo-blocking
TCP/3306	MySQL	127.0.0.1:3306	รับการเชื่อมต่อเฉพาะ localhost ตามผลคำสั่ง ss -tulpn

ตารางที่ 3.3 การกำหนดพอร์ตเครือข่ายและประเด็นด้านความปลอดภัย

```
azureuser@Papaya:~$ nslookup papayapogpog.duckdns.org
Server:         127.0.0.53
Address:        127.0.0.53#53

Non-authoritative answer:
Name:   papayapogpog.duckdns.org
Address: 20.222.194.35
```

ภาพที่ 3.3 การตรวจสอบ DNS ด้วย nslookup



ภาพที่ 3.4 กฎ Inbound Security Rules ของ Azure NSG

3.5 การติดตั้งและตั้งค่า Web Stack

ระบบใช้ Nginx เป็นเว็บเซิร์ฟเวอร์ PHP-FPM สำหรับประมวลผล PHP WordPress เป็นระบบจัดการเนื้อหา และ MySQL เป็นระบบฐานข้อมูล ภาพหลักฐานเวอร์ชันที่ได้รับระบุ Nginx 1.24.0, PHP

8.3.6 และ MySQL 8.0.46 ขณะที่ WordPress เป็นรุ่น 7.1.3 และใช้ธีม Twenty Twenty-Five การทำงานจริงต้องสอดคล้องกันใน 3 ประเด็น ได้แก่

1. Nginx ต้องอ้างอิง document root ของ WordPress
2. PHP-FPM ต้องเปิดรับคำขอจาก Nginx ผ่าน socket ที่ถูกต้อง
3. ค่าการเชื่อมต่อฐานข้อมูลใน WordPress ต้องใช้บัญชีและฐานข้อมูลที่มีสิทธิ์เหมาะสม

การตรวจสอบ syntax ของ Nginx ใช้คำสั่ง nginx -t ซึ่งผลล่าสุดผ่านการตรวจสอบและแสดงข้อความ test successful ส่วน PHP-FPM และ MySQL อยู่ในสถานะ active (running) การที่บริการอยู่ในสถานะ active เป็นหลักฐานว่ากระบวนการทำงานอยู่ แต่ควรประกอบด้วยหลักฐานหน้า WordPress ผ่าน HTTPS และการทำงานของระบบจัดการเนื้อหา เพื่อยืนยันการทำงานร่วมกัน (integration) ในระดับแอปพลิเคชัน

3.6 การติดตั้งใบรับรองและตั้งค่า HTTPS

ข้อมูลโครงการระบุว่าใช้ใบรับรอง Let's Encrypt ชนิด ECDSA สำหรับโดเมน papayapogpog.duckdns.org และตั้งค่าให้ HTTP เปลี่ยนเส้นทาง (redirect) ไปยัง HTTPS ตามผลสรุปเดิม คำสั่งที่ใช้ในการตรวจสอบประกอบด้วย certbot certificates, certbot renew --dry-run และ curl -I สำหรับ URL แบบ HTTP และ HTTPS ทั้งนี้ ควรบันทึกวันและเวลาที่รันคำสั่ง เพื่อให้เทียบกับวันหมดอายุของใบรับรองได้

3.7 การเสริมความปลอดภัย

3.7.1 Azure Network Security Group (NSG)

ผลการตรวจสอบที่ผู้จัดทำนำส่งระบุ NSG ชื่อ Papaya-nsg โดยมีกฎดังตารางที่ 3.4

Priority	พอร์ต/บริการ	Action	Source
300	TCP/80 (HTTP)	Allow	Any
320	TCP/443 (HTTPS)	Allow	Any
340	TCP/22 (SSH)	Allow	Any
ค่าเริ่มต้น	ทราฟฟิกอื่นทั้งหมด	Deny (DenyAllInbound)	Any

ตารางที่ 3.4 กฎ Inbound ของ NSG ชื่อ Papaya-nsg

การกำหนด Source เป็น Any ทำให้ NSG ไม่ได้จำกัดประเทศหรือ IP ต้นทาง สำหรับพอร์ตเหล่านี้ จึงต้องอาศัยกฎระดับเครื่องเสมือนเพิ่มเติมสำหรับการกรองทราฟฟิกเว็บ และควรจำกัด SSH ให้แคบลงหากสภาพแวดล้อมเอื้ออำนวย

3.7.2 iptables/ipset Geo-blocking

ตามรายการกฎล่าสุดที่ผู้จัดทำนำส่ง กฎลำดับต้นอนุญาต loopback และ IP ที่ระบุสำหรับ private/public interface จากนั้นกฎ DROP จะทิ้งทราฟฟิก TCP/80 และ TCP/443 เมื่อ IP ต้นทางไม่อยู่ใน ipset ชื่อ thailand โครงสร้างนี้ออกแบบให้การกรองตามประเทศทำงานที่ชั้นระบบปฏิบัติการ อย่างไรก็ตาม การเรียงลำดับกฎมีผลต่อผลลัพธ์ และหลักฐานก่อนหน้าที่นำส่งมีภาพแสดงรูปแบบกฎแตกต่างจากรายการล่าสุด จึงควรแทรกภาพผลคำสั่งล่าสุดจากการรันครั้งเดียว เพื่อให้ตรวจสอบลำดับและเงื่อนไขของกฎได้ชัดเจน

3.7.3 SSH Hardening และ Fail2ban

ข้อมูลการตั้งค่า SSH ที่ได้รับก่อนหน้าระบุค่าดังตารางที่ 3.5 โดยใช้บัญชี azureuser และกุญแจชนิด Ed25519

พารามิเตอร์	ค่าที่ตั้ง	ความหมาย
PermitRootLogin	no	ไม่อนุญาตให้ล็อกอินด้วยบัญชี root
PasswordAuthentication	no	ไม่อนุญาตให้ยืนยันตัวตนด้วยรหัสผ่าน
KbdInteractiveAuthentication	no	ไม่อนุญาตการยืนยันตัวตนแบบ keyboard-interactive
PubkeyAuthentication	yes	อนุญาตการยืนยันตัวตนด้วยกุญแจสาธารณะ

ตารางที่ 3.5 การตั้งค่า SSH เพื่อเสริมความปลอดภัย

ส่วน Fail2ban เปิดใช้งาน jail ชื่อ sshd เพื่อเฝ้าระวังความพยายามล็อกอินที่ผิดพลาด ข้อมูลปัจจุบันรายงานจำนวนความพยายามที่ล้มเหลว 317 ครั้ง และ IP ที่ถูกห้าม (ban) 22 รายการ

3.8 แผนการทดสอบระบบ

แผนการทดสอบระบบแสดงไว้ในตารางที่ 3.6

รหัสการทดสอบ	รายการตรวจสอบ	หลักฐาน / คำสั่ง	เกณฑ์ผ่าน
T-01	การแปลงชื่อ DNS	nslookup papayapogpog.duckdns.org	ตอบกลับ IP ปัจจุบันที่กำหนด
T-02	สถานะบริการระบบ	systemctl status nginx php8.3-fpm mysql fail2ban	ทุกบริการมีสถานะ Active: active (running)
T-03	พอร์ตที่รับฟัง	sudo ss -tulpn	พอร์ต 22/80/443 ตรงกับบริการ และ MySQL อยู่ที่ localhost
T-04	Syntax ของ Nginx	sudo nginx -t	แสดง syntax is ok และ test is successful
T-05	TLS และการต่ออายุ	sudo certbot certificates; sudo certbot renew --dry-run	โดเมนถูกต้องและ dry-run สำเร็จ
T-06	กฎ NSG	Azure Portal: Papaya-nsg inbound rules	กฎพอร์ต 22/80/443 และ DenyAllInbound ตรงกับนโยบาย
T-07	Geo-blocking	ผลคำสั่ง iptables/ipset และการทดสอบจากต้นทาง	กฎและผลการเข้าถึงสอดคล้องกับชุด IP ที่อนุญาต
T-08	Fail2ban	sudo fail2ban-client status sshd	บริการทำงานและเห็นค่า counters ตามผลตรวจ
T-09	การทำงานร่วมกันของ WordPress	เปิด URL ผ่าน HTTPS และตรวจสอบหน้าเว็บ	หน้า WordPress แสดงผลและจัดการเนื้อหาได้

ตารางที่ 3.6 แผนการทดสอบระบบ

บทที่ 4

ผลการทดสอบและวิเคราะห์ผล

บทนี้นำเสนอผลการทดสอบระบบเว็บเซิร์ฟเวอร์ WordPress บนเครื่องเสมือนของ Microsoft Azure ตามแผนการทดสอบในบทที่ 3 ประกอบด้วยวิธีการประเมินผล ผลการตรวจสอบสถานะบริการ พอร์ตเครือข่าย Nginx และใบรับรอง TLS มาตรการรักษาความปลอดภัย การทำงานของ WordPress สรุปผลการทดสอบ รวมถึงข้อจำกัดของหลักฐาน

4.1 วิธีการประเมินผล

บทนี้สรุปผลตามเอาต์พุตของระบบ (System Outputs) และข้อมูลการตรวจสอบที่ผู้จัดทำนำส่ง โดยไม่สร้างค่าทดสอบใหม่ขึ้นแทนผลจริง หลักฐานจัดกลุ่มตามสถานะบริการ พอร์ตเครือข่าย ไวยากรณ์ (syntax) ของ Nginx ใบรับรอง TLS กฎ Azure NSG กฎ iptables/ipset และ Fail2ban ทั้งนี้ ตำแหน่งวางภาพหน้าจอในบทนี้ใช้สำหรับแทรกภาพต้นฉบับจากเครื่องจริงก่อนส่งรายงาน เพื่อให้ผู้อ่านตรวจสอบข้อความเทียบกับผลคำสั่งหรือหน้า Azure Portal ได้

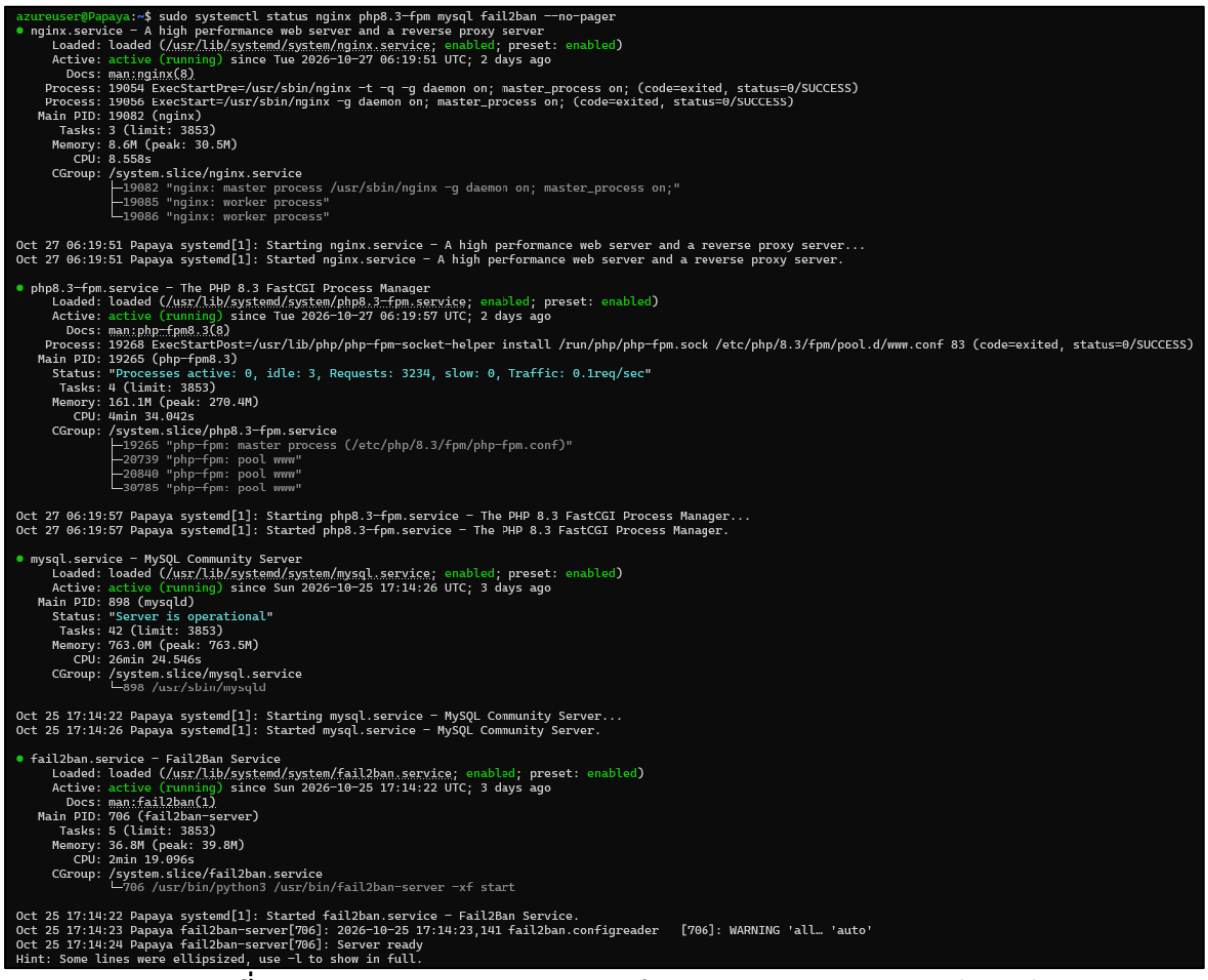
4.2 ผลการตรวจสถานะบริการหลัก

ผลการตรวจสถานะบริการหลักแสดงไว้ในตารางที่ 4.1

บริการ	ผลการตรวจที่ได้รับ	การตีความผล
Nginx Web Server	Active (running); มี master process และ worker processes 2 ตัว	เว็บเซิร์ฟเวอร์ทำงานในช่วงตรวจสอบ
PHP 8.3-FPM	Active (running); ประมวลผลสะสม 2,912 requests; active 0, idle 3	PHP-FPM ทำงาน และมีคำขอสะสมตามเอาต์พุต ณ จุดตรวจไม่มี worker ที่ active และมี idle worker 3 ตัว
MySQL Database	Active (running); PID 898; หน่วยความจำประมาณ 758 MB	บริการฐานข้อมูลทำงานในช่วงตรวจสอบ ค่าหน่วยความจำเป็นค่าที่รายงาน ณ ขณะตรวจ (snapshot)
Fail2ban	Active (running); พร้อมตรวจสอบ SSH	บริการตรวจจับและบังคับใช้นโยบายตาม jail ที่ตั้งค่าไว้ทำงานอยู่

ตารางที่ 4.1 ผลการตรวจสถานะบริการหลัก

ผลการตรวจยืนยันว่าส่วนประกอบหลักทำงานอยู่ในขณะเก็บหลักฐาน แต่ยังมิใช่การทดสอบความทนทานต่อโหลดสูงหรือการรับประกันความพร้อมใช้งานในระยะยาว จำนวน requests ของ PHP-FPM เป็นตัวนับตามเอาต์พุตและไม่ระบุช่วงเวลาสะสม จึงไม่นำมาคำนวณจำนวนคำขอต่อวินาที (requests per second)



ภาพที่ 4.1 ผลการตรวจสอบสถานะการทำงานของบริการหลักบนเซิร์ฟเวอร์

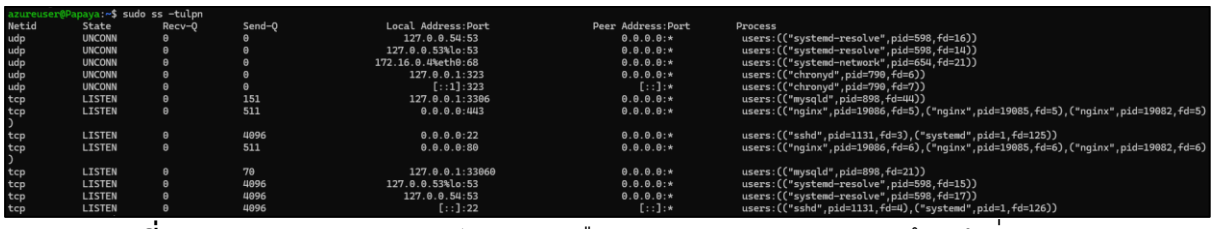
4.3 ผลการตรวจพอร์ตที่เปิดใช้งาน

ผลจากคำสั่ง sudo ss -tulpn ระบุ listener ของบริการเว็บและ SSH รวมถึงการผูก MySQL ไว้ที่ loopback ดังตารางที่ 4.2

พอร์ต / ที่อยู่ที่รับฟัง	บริการ	ผลการตรวจ	นัยด้านความปลอดภัย
0.0.0.0:80	Nginx / HTTP	รับการเชื่อมต่อบน IPv4 ทุก interface	ต้องควบคุมด้วย NSG และไฟร์วอลล์ของเครื่อง (host firewall)

0.0.0.0:443	Nginx / HTTPS	รับการเชื่อมต่อบน IPv4 ทุก interface	เป็นจุดรับการเชื่อมต่อ TLS จากผู้ใช้
0.0.0.0:22 **และ** [::]:22	sshd / SSH	รับการเชื่อมต่อบน IPv4 และ IPv6	ควรจำกัดแหล่งที่มาที่ NSG และใช้ key-only
127.0.0.1:3306	MySQL	รับการเชื่อมต่อเฉพาะ IPv4 loopback	ไม่มี listener ของ MySQL บน public interface ตามผลนี้

ตารางที่ 4.2 ผลการตรวจพอร์ตที่รับฟังและนัยด้านความปลอดภัย



ภาพที่ 4.2 ผลการตรวจสอบพอร์ตบริการเครือข่ายและสถานะ Listener ด้วยคำสั่ง ss -tulpn

4.4 ผลการตรวจ Nginx และใบรับรอง TLS

ผลการตรวจ Nginx และใบรับรอง TLS แสดงไว้ในตารางที่ 4.3

รายการตรวจสอบ	ผลที่รายงาน	สรุป
Nginx syntax	nginx -t: syntax is ok; test is successful	ผ่านการตรวจ syntax และการทดสอบ configuration
ผู้ออกใบรับรอง (Issuer)	Let's Encrypt	มีการออกใบรับรองสำหรับโดเมนที่ระบุ
ชนิดใบรับรอง	ECDSA	ชนิดกุญแจตามข้อมูลการตรวจสอบ
โดเมน	papayapogpog.duckdns.org	ตรงกับโดเมนของโครงการ
วันหมดอายุ	21 มกราคม พ.ศ. 2570 (ค.ศ. 2027) เหลืออีก 84 วัน ณ เวลาตรวจ	ควรบันทึกวันและเวลาที่ได้เอาต์พุต เนื่องจากจำนวนวันที่เหลือเปลี่ยนตามวันตรวจ
การทดสอบการต่ออายุ (dry-run)	ผลก่อนหน้าระบุว่า simulated renewals succeeded	ยืนยันว่าการจำลองการต่ออายุสำเร็จ ณ เวลาที่ทดสอบ

ตารางที่ 4.3 ผลการตรวจ Nginx และใบรับรอง TLS

```
azureuser@Papaya:~$ sudo nginx -t
nginx: the configuration file /etc/nginx/nginx.conf syntax is ok
nginx: configuration file /etc/nginx/nginx.conf test is successful
```

ภาพที่ 4.3 ผลการตรวจสอบไวยากรณ์และความถูกต้องของไฟล์กำหนดค่า Nginx

```
azureuser@Papaya:~$ sudo certbot certificates && sudo certbot renew --dry-run
Saving debug log to /var/log/letsencrypt/letsencrypt.log

- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
Found the following certs:
  Certificate Name: papayapogpog.duckdns.org
    Serial Number: 5158838d1d2b1caede7486e3c3afa63b7d1
    Key Type: ECDSA
    Domains: papayapogpog.duckdns.org
    Expiry Date: 2027-01-21 13:51:56+00:00 (VALID: 84 days)
    Certificate Path: /etc/letsencrypt/live/papayapogpog.duckdns.org/fullchain.pem
    Private Key Path: /etc/letsencrypt/live/papayapogpog.duckdns.org/privkey.pem
- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
Saving debug log to /var/log/letsencrypt/letsencrypt.log

- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
Processing /etc/letsencrypt/renewal/papayapogpog.duckdns.org.conf
- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
Simulating renewal of an existing certificate for papayapogpog.duckdns.org

- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
Congratulations, all simulated renewals succeeded:
  /etc/letsencrypt/live/papayapogpog.duckdns.org/fullchain.pem (success)
- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
```

ภาพที่ 4.4 ผลการตรวจสอบสถานะใบรับรอง SSL/TLS และการจำลองต่ออายุด้วย Certbot

4.5 ผลการตรวจ NSG, iptables/ipset และ Fail2ban

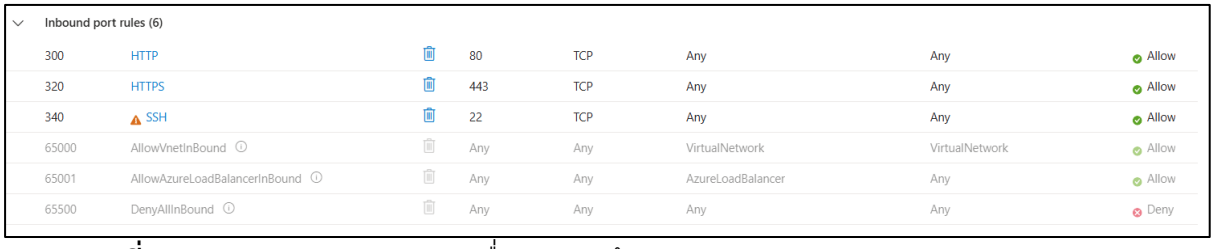
4.5.1 Azure Network Security Group (NSG)

กฎ Inbound ของ NSG แสดงไว้ในตารางที่ 4.4

Priority / กฎ	พอร์ต	Source	Action
300 — HTTP	TCP/80	Any	Allow
320 — HTTPS	TCP/443	Any	Allow
340 — SSH	TCP/22	Any	Allow
ค่าเริ่มต้น — DenyAllInbound	ทราฟฟิกที่ไม่ตรงกับกฎอื่น	ตามกฎค่าเริ่มต้น	Deny

ตารางที่ 4.4 ผลการตรวจกฎ Inbound ของ Azure NSG

กฎ NSG ที่ได้รับแสดงว่า TCP/22, TCP/80 และ TCP/443 ถูกอนุญาตจากทุกแหล่งที่มา (Any) ที่ชั้นของ Azure ส่วนกฎ DenyAllInbound เป็นค่าเริ่มต้นสำหรับทราฟฟิกขาเข้าที่ไม่ตรงกับกฎก่อนหน้า [3] ดังนั้น การจำกัด HTTP/HTTPS ให้เฉพาะ IP ของประเทศไทยจึงมิได้เกิดจาก NSG ตามรายการนี้ แต่มอบหมายให้กฎภายในเครื่องเสมือน ซึ่งผู้จัดทำระบุว่าใช้ iptables/ipset



Inbound port rules (6)

300	HTTP		80	TCP	Any	Any	Allow
320	HTTPS		443	TCP	Any	Any	Allow
340	SSH		22	TCP	Any	Any	Allow
65000	AllowVnetInBound		Any	Any	VirtualNetwork	VirtualNetwork	Allow
65001	AllowAzureLoadBalancerInBound		Any	Any	AzureLoadBalancer	Any	Allow
65500	DenyAllInBound		Any	Any	Any	Any	Deny

ภาพที่ 4.5 ผลการตรวจสอบกฎการเชื่อมต่อขาเข้า (Inbound Security Rules) บน Azure NSG

4.5.2 iptables/ipset Geo-blocking

ตามผลตรวจล่าสุดที่ได้รับ กฎภายในเครื่องเสมือนประกอบด้วยการยอมรับ (ACCEPT) loopback การยอมรับที่อยู่ private/public ที่ระบุ และกฎ DROP สำหรับ TCP/80 และ TCP/443 เมื่อ IP ต้นทางไม่อยู่ใน ipset ชื่อ thailand ผู้จัดทำระบุว่าการบล็อกทราฟฟิกจากต่างประเทศทำงานสำเร็จ อย่างไรก็ตาม ภาพหลักฐานรุ่นก่อนหน้าแสดงลำดับกฎแตกต่างจากสรุปล่าสุด ภาพยืนยันฉบับสุดท้ายจึงควรเป็นผลจากการรันคำสั่งต่อไปนี้ในช่วงเวลาเดียวกัน เพื่อยืนยันกฎที่ใช้งานอยู่และลำดับการประมวลผลก่อนประกาศผลขั้นสุดท้าย

- iptables -L INPUT -n --line-numbers
- iptables -S INPUT
- ipset list thailand

```
azureuser@Papaya:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
|  |- Currently failed: 0
|  |- Total failed:     7
|  `- Journal matches:  _SYSTEMD_UNIT=sshd.service + _COMM=sshd
`- Actions
   |- Currently banned: 2
   |- Total banned:     2
   `- Banned IP list:   45.148.10.240 2.57.122.238
```

ภาพที่ 4.6 ผลการตรวจสอบกฎความปลอดภัยบน iptables และการเปิดใช้งาน Geo-blocking ร่วมกับ IP set

4.5.3 Fail2ban SSH Jail

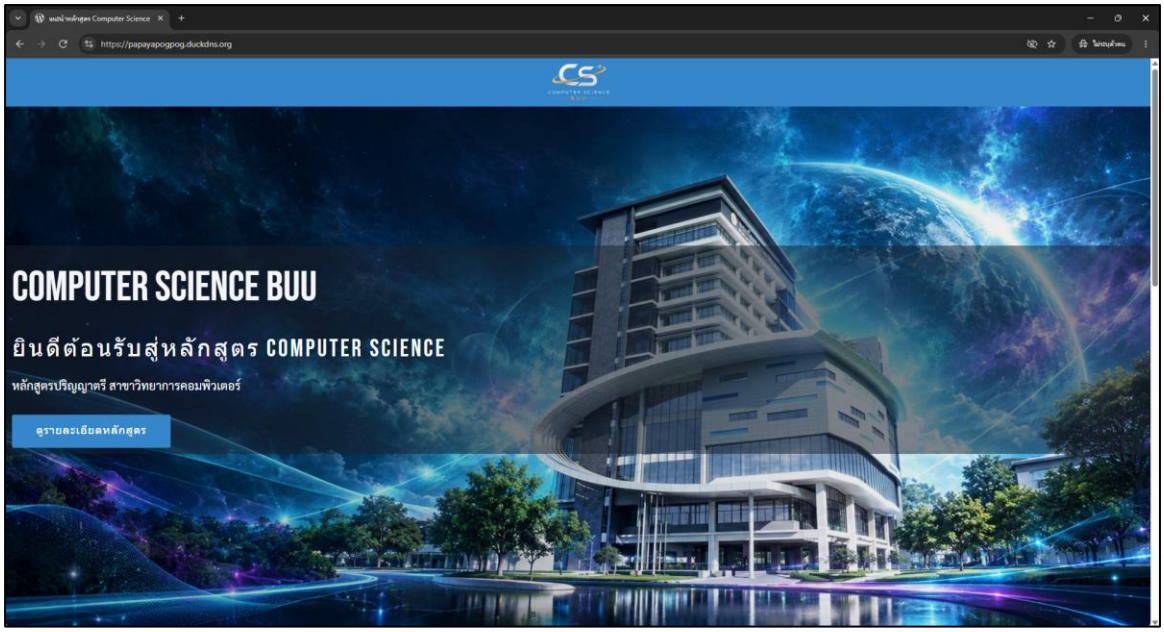
ผลตรวจ Fail2ban ระบุว่าบริการอยู่ในสถานะ Active (running) มีจำนวนความพยายามที่ล้มเหลว 317 ครั้ง และมี IP ที่ถูกห้าม (ban) 22 รายการ ข้อมูลนี้เป็นหลักฐานว่าระบบเฝ้าระวัง SSH และบังคับใช้นโยบายกับ IP ตามตัวนับในช่วงที่เก็บผล อย่างไรก็ตาม การสรุปผลควรอ้างอิงเอาต์พุตของคำสั่ง fail2ban-client status sshd พร้อมเวลาที่บันทึก (timestamp) เนื่องจากตัวนับและรายการ IP ที่ถูกห้ามอาจเปลี่ยนแปลงเมื่อระบบทำงานต่อเนื่อง

```
azureuser@Papaya:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
|  |- Currently failed: 0
|  |- Total failed:     7
|  `- Journal matches:  _SYSTEMD_UNIT=sshd.service + _COMM=sshd
`- Actions
   |- Currently banned: 2
   |- Total banned:     2
   `- Banned IP list:   45.148.10.240 2.57.122.238
```

ภาพที่ 4.7 ผลการตรวจสอบสถานะการป้องกันการโจมตีทาง SSH ด้วย Fail2ba

4.6 **ผลการตรวจการทำงานของ** WordPress

ภาพหน้าเว็บไซต์ที่ได้รับแสดงหน้า “Computer Science Buu” และการเข้าถึงผ่าน URL แบบ HTTPS ของโดเมนโครงการ จึงเป็นหลักฐานเชิงภาพว่าหน้าเว็บไซต์ส่วนหน้า (front end) แสดงผลได้ ณ เวลาถ่ายภาพ เมื่อพิจารณาร่วมกับสถานะของ Nginx, PHP-FPM และ MySQL ที่รายงานว่าทำงานอยู่ จะสนับสนุนว่าระบบทำงานร่วมกันได้ในภาพรวม อย่างไรก็ตาม หากต้องการยืนยันการทำงานของแต่ละชั้นอย่างแยกส่วน ควรเพิ่มหลักฐานการเปิดหน้าจัดการ WordPress หลังเข้าสู่ระบบ การแสดงหน้าเนื้อหา และการตรวจสอบว่าฐานข้อมูลไม่เปิดสู่ภายนอก



ภาพที่ 4.8 ผลการเข้าถึงหน้าเว็บไซต์ WordPress ผ่านโปรโตคอล HTTPS

4.7 สรุปผลการทดสอบตามรายการ

สรุปผลการทดสอบตามแผนในตารางที่ 3.6 แสดงไว้ในตารางที่ 4.5

รหัสการทดสอบ	รายการ	สถานะ	หมายเหตุ
T-02	บริการหลัก	PASS	ดูผลในหัวข้อ 4.2
T-03	พอร์ตที่รับฟัง	PASS	MySQL รับเฉพาะ localhost (3306)
T-04	Nginx syntax	PASS	nginx -t ผ่านการทดสอบ
T-05	TLS / การต่ออายุ	PASS ตามเอาต์พุต	หมดอายุ 21 มกราคม พ.ศ. 2570
T-06	Azure NSG	CONFIGURED	SSH ตั้ง Source เป็น Any
T-07	Geo-blocking	รายงานว่า PASS	ต้องแนบกฎล่าสุดและผลทดสอบ
T-08	Fail2ban	PASS	ล้มเหลว 317 ครั้ง / ถูกห้าม 22 IP
T-09	WordPress	PASS ตามภาพ	ต้องแนบภาพล่าสุด

ตารางที่ 4.5 สรุปผลการทดสอบตามรหัสการทดสอบ

4.8 ข้อจำกัดและความสอดคล้องของหลักฐาน

1. ข้อมูลการทดสอบส่วนใหญ่เป็น snapshot ณ ช่วงเวลาที่รันคำสั่ง ตัวเลขของ process, หน่วยความจำ, ตัวนับ request และ Fail2ban เปลี่ยนแปลงได้ตามการใช้งาน ส่วนผล Certbot dry-run เป็นผลการจำลอง ณ เวลาทดสอบ มิได้รับประกันการต่ออายุในอนาคตหาก DNS หรือไฟร์วอลล์เปลี่ยนแปลง
2. NSG เปิด TCP/22 จากทุกแหล่งที่มา (Any) ตามข้อมูลที่ได้รับ จึงควรพิจารณาจำกัดต้นทางของ SSH ให้เหลือเฉพาะ IP ของผู้ดูแลระบบเมื่อสามารถทำได้
3. ผล Geo-blocking ต้องยืนยันจากกฎล่าสุดและการทดสอบจากต้นทางที่ได้รับอนุญาตและไม่ได้รับอนุญาต เนื่องจากภาพก่อนหน้ากับสรุปล่าสุดแสดงลำดับกฎไม่ตรงกัน นอกจากนี้ ยังไม่มีผลการทดสอบภาระงาน (load test) หรือ benchmark จึงไม่อาจระบุจำนวนผู้ใช้พร้อมกันสูงสุดหรือสมรรถนะเชิงปริมาณของระบบได้

บทที่ 5

สรุปผลและข้อเสนอแนะ

5.1 สรุปผลการดำเนินงาน

โครงงานนี้ออกแบบและให้บริการเว็บไซต์ WordPress บนเครื่องเสมือนของ Microsoft Azure โดยใช้ระบบปฏิบัติการ Ubuntu Server 24.04.5 LTS ร่วมกับ Nginx, PHP-FPM, WordPress และ MySQL ผ่านโดเมน papayapogpog.duckdns.org ผลการตรวจสอบที่ได้รับระบุว่า Nginx, PHP-FPM, MySQL และ Fail2ban อยู่ในสถานะ active (running) และ Nginx ผ่านการตรวจสอบ syntax นอกจากนี้ Nginx รับการเชื่อมต่อที่ TCP/80 และ TCP/443 ขณะที่ SSH ใช้ TCP/22 และ MySQL ผูกกับ 127.0.0.1:3306

ในด้าน HTTPS ข้อมูลระบุว่าใบรับรอง Let's Encrypt ชนิด ECDSA ครอบคลุมชื่อโดเมนของโครงการ และมีวันหมดอายุคือ 21 มกราคม พ.ศ. 2570 (ค.ศ. 2027) โดยผลการตรวจสอบ Certbot dry-run ก่อนหน้านี้ระบุว่าการจำลองการต่ออายุสำเร็จ ในด้านเครือข่าย Azure NSG อนุญาตพอร์ต 22, 80 และ 443 จากทุกแหล่งที่มา (Any) ขณะที่ข้อมูลล่าสุดของผู้จัดทำระบุว่ามีการใช้ iptables/ipset จำกัดทราฟฟิกเว็บตามชุด IP ของประเทศไทย และ Fail2ban รายงานความพยายามที่ล้มเหลว 317 ครั้ง กับ IP ที่ถูกห้าม (ban) 22 รายการ

ผลดังกล่าวแสดงให้เห็นว่าระบบรวมองค์ประกอบเครือข่ายและเว็บเซิร์ฟเวอร์หลายชั้นไว้ในเครื่องเสมือนเครื่องเดียว และมีหลักฐานการตรวจสอบเบื้องต้นสำหรับบริการสำคัญ อย่างไรก็ตาม ความสมบูรณ์ของข้อสรุปด้าน Geo-blocking ต้องอาศัยภาพกฎ iptables/ipset ล่าสุดที่สอดคล้องกับผลสรุป และการทดสอบจากต้นทางต่างเครือข่าย ส่วนข้อสรุปด้านความพร้อมใช้งานและความสามารถในการรองรับโหลดสูงยังต้องมีแผนการทดสอบเพิ่มเติม

5.2 ข้อจำกัดของระบบ

ข้อจำกัดของระบบสรุปได้ดังตารางที่ 5.1

ลำดับ	ข้อจำกัด	ผลกระทบ / ข้อพิจารณา
1	Web Server, PHP-FPM และฐานข้อมูลอยู่บนเครื่องเสมือนเดียวกัน	มีจุดล้มเหลวหลักเพียงจุดเดียว (Single Point of Failure) และใช้ทรัพยากร CPU/RAM ร่วมกัน

2	Azure NSG อนุญาต SSH จากทุกแหล่งที่มา (Any)	แม้มี key-only authentication และ Fail2ban ก็ยังควรลดพื้นผิวการโจมตีด้วยการจำกัด Source IP
3	Geo-blocking อาศัยชุด IP ใน ipset	ต้องปรับปรุงข้อมูลให้ถูกต้องอยู่เสมอ และอาจกระทบผู้ใช้หรือบริการตรวจสอบที่เชื่อมต่อจากนอกชุดที่อนุญาต
4	โดเมนเป็นโดเมนย่อยฟรี (Free subdomain) ภายใต้ DuckDNS	การควบคุมชื่อโดเมนและเงื่อนไขของบริการขึ้นกับผู้ให้บริการ ต่างจากโดเมนที่จดทะเบียนในนามองค์กร
5	หลักฐานบางส่วนอยู่ในรูปคำสรุปผล มิใช่ภาพเอาต์พุตดิบ (raw output) พร้อม timestamp	ผล Geo-blocking มีภาพก่อนหน้าที่แสดงรายละเอียดกฎไม่ตรงกับสรุปล่าสุด
6	ไม่มีผล load test, backup restore test, uptime monitoring หรือ disaster recovery test ที่เพียงพอ	ไม่สามารถสรุปคุณสมบัติด้านสมรรถนะ ความพร้อมใช้งาน และการกู้คืนระบบได้

ตารางที่ 5.1 ข้อจำกัดของระบบและผลกระทบ

5.3 ข้อเสนอแนะเพื่อการพัฒนา

ข้อเสนอแนะจัดลำดับตามความสำคัญดังตารางที่ 5.2

ลำดับความสำคัญ	ข้อเสนอแนะ	เหตุผล / ผลที่คาดหวัง
สูง	จำกัด Azure NSG สำหรับ SSH (TCP/22) ให้รับเฉพาะ IP หรือช่วง IP ของผู้ดูแลระบบที่เชื่อถือได้	ลดการเปิดเผยบริการ SSH จากทุกต้นทาง
สูง	รวบรวมผลคำสั่ง iptables-save, iptables -S INPUT, iptables -L INPUT -v -n --line-numbers และ ipset list จากการตรวจครั้งเดียว	ยืนยันลำดับกฎและความสอดคล้องของ Geo-blocking
สูง	ทดสอบการเข้าถึงจากแหล่งที่ได้รับอนุญาตและไม่ได้รับอนุญาต พร้อมบันทึกเวลาทดสอบและ HTTP response	ยืนยันผลเชิงพฤติกรรม มิใช่อาศัยเพียงการมีกฎ

สูง	เปลี่ยน DuckDNS Token ที่ปรากฏในภาพหลักฐานและปรับปรุงสคริปต์ที่เกี่ยวข้อง	ลดความเสี่ยงจากการรั่วไหลของข้อมูลลับ
กลาง	ตั้งระบบแจ้งเตือนวันหมดอายุของใบรับรอง และตรวจสอบ Certbot timer และ renewal logs เป็นระยะ	ลดโอกาสที่เว็บไซต์หยุดให้บริการเนื่องจากใบรับรองหมดอายุ
กลาง	จัดทำขั้นตอนสำรองข้อมูลไฟล์ WordPress และฐานข้อมูล พร้อมทดสอบการกู้คืน	ช่วยฟื้นฟูระบบเมื่อเกิดข้อผิดพลาดหรือข้อมูลเสียหาย
กลาง	ติดตามการปรับปรุงแพตช์ความปลอดภัยของ Ubuntu, Nginx, PHP, WordPress และ MySQL	ลดความเสี่ยงจากช่องโหว่ที่มีการแก้ไขแล้ว
ระยะถัดไป	เพิ่มระบบเฝ้าระวัง (monitoring) การตรวจสุขภาพระบบ (health check) และทดสอบโหลดในขอบเขตที่กำหนด	ช่วยวัดความเสถียรและขีดความสามารถด้วยข้อมูลที่ทำซ้ำได้
ระยะถัดไป	พิจารณาแยกฐานข้อมูลหรือใช้บริการฐานข้อมูลแบบ managed เมื่อระบบขยายตัว	แยกภาระงานและเพิ่มความสะดวกในการดูแลระบบ

ตารางที่ 5.2 ข้อเสนอแนะเพื่อการพัฒนาระบบ

5.4 บทสรุปสุดท้าย

โครงงานนี้แสดงให้เห็นการทำงานร่วมกันของบริการเครือข่ายและส่วนประกอบเว็บในสภาพแวดล้อมคลาวด์จริง โดยใช้การตรวจสอบสถานะบริการ การตรวจสอบพอร์ต การตรวจสอบ syntax ของ Nginx และการตรวจสอบใบรับรอง TLS เป็นหลักฐานเชิงปฏิบัติ ตลอดจนนำ NSG, ไฟร์วอลล์ระดับเครื่อง (host firewall), SSH แบบ key-only และ Fail2ban มาใช้ตามข้อมูลที่รายงาน ทั้งนี้ ความน่าเชื่อถือของรายงานฉบับสมบูรณ์จะเพิ่มขึ้นเมื่อแนบภาพหน้าจอต้นฉบับในตำแหน่งที่กำหนด ยืนยันกฎ Geo-blocking จากการตั้งค่าล่าสุด และเก็บผลการทดสอบจากต้นทางที่แตกต่างกันอย่างเป็นระบบ

เอกสารอ้างอิง

[1] WordPress.org. (ม.ป.ป.). *Requirements*. สืบค้นเมื่อ 28 ตุลาคม 2569, จาก https://wordpress.org/about/requirements/

[2] NGINX, Inc. (ม.ป.ป.). *Module ngx_http_fastcgi_module*. สืบค้นเมื่อ 28 ตุลาคม 2569, จาก https://nginx.org/en/docs/http/ngx_http_fastcgi_module.html

[3] Microsoft. (ม.ป.ป.). *How network security groups filter network traffic in Azure*. Microsoft Learn. สืบค้นเมื่อ 28 ตุลาคม 2569, จาก https://learn.microsoft.com/en-us/azure/virtual-network/network-security-group-how-it-works

[4] Electronic Frontier Foundation. (ม.ป.ป.). *Certbot instructions: Nginx on Ubuntu*. สืบค้นเมื่อ 28 ตุลาคม 2569, จาก https://certbot.eff.org/instructions?os=snap&ws=nginx

[5] Oracle Corporation. (ม.ป.ป.). *MySQL 8.0 reference manual: Server system variables*. สืบค้นเมื่อ 28 ตุลาคม 2569, จาก https://dev.mysql.com/doc/refman/8.0/en/server-system-variables.html

[6] Fail2ban Project. (ม.ป.ป.). *jail.conf configuration file*. GitHub. สืบค้นเมื่อ 28 ตุลาคม 2569, จาก https://github.com/fail2ban/fail2ban/blob/master/config/jail.conf

[7] Fielding, R., Nottingham, M., & Reschke, J. (2022). *HTTP semantics* (RFC 9110). RFC Editor. https://www.rfc-editor.org/rfc/rfc9110.html

[8] Rescorla, E. (2018). *The Transport Layer Security (TLS) protocol version 1.3* (RFC 8446). RFC Editor. https://www.rfc-editor.org/rfc/rfc8446.html

[9] Mockapetris, P. (1987). *Domain names—concepts and facilities* (RFC 1034). RFC Editor. https://www.rfc-editor.org/rfc/rfc1034.html

ภาคผนวก ก รายการภาพหน้าจอหลักฐาน

ภาคผนวกนี้รวบรวมรายการภาพหน้าจอหลักฐานที่ต้องแทรกในรายงาน โดยให้แทนที่กรอบพื้นที่วางภาพ (Placeholder) ในเนื้อหาด้วยภาพต้นฉบับจากเครื่องจริง ภาพที่นำมาแทรกต้องแสดงคำสั่งหรือหน้าจอที่เกี่ยวข้องครบถ้วนและอ่านได้ชัดเจน และควรระบุวันที่และเวลาที่เก็บหลักฐานไว้ในชื่อไฟล์หรือคำบรรยายภาพ

ตารางที่ ก.1 รายการภาพหน้าจอหลักฐานที่ต้องแทรกในรายงาน

รหัสภาพ	ภาพที่ต้องแทรก	แหล่งหลักฐาน / สิ่งที่ต้องมองเห็น
3.1	ภาพรวมเครื่องเสมือน Azure (Azure VM overview)	Azure Portal: ชื่อ Papaya, ขนาด (size), Region, ระบบปฏิบัติการ, ดิสก์ และ Public IP
3.2	สถาปัตยกรรมระบบ	แผนภาพ (diagram) ที่จัดทำในรายงาน ไม่ใช่ภาพหน้าจอจากระบบ
3.3	การแปลงชื่อ DNS (DNS resolution)	PowerShell: nslookup papayapogpog.duckdns.org
3.4	กฎของ Azure NSG	Papaya-nsg: Priority, Source, พอร์ต, Action และกฎค่าเริ่มต้น
4.1	สถานะบริการ (Service status)	systemctl status ของ Nginx, PHP-FPM, MySQL และ Fail2ban
4.2	พอร์ตที่รับฟัง (Listening ports)	sudo ss -tulpn
4.3	Syntax ของ Nginx	sudo nginx -t
4.4	TLS และการต่ออายุใบรับรอง	sudo certbot certificates และ sudo certbot renew --dry-run
4.5	กฎ NSG ในส่วนผลการทดสอบ	ภาพกฎเดียวกับภาพ 3.4 หากเหมาะสมให้ใช้หลักฐานเดียวกัน
4.6	iptables/ipset	iptables -S INPUT, iptables -L INPUT -n --line-numbers และ ipset list thailand
4.7	Fail2ban	sudo fail2ban-client status sshd ที่แสดงค่า counters
4.8	หน้าเว็บไซต์ WordPress (frontend)	เบราว์เซอร์เปิดหน้าเว็บไซต์จริงผ่าน HTTPS

ภาคผนวก ข คำสั่งตรวจสอบที่ใช้

คำสั่งในภาคผนวกนี้เป็นรายการสำหรับเก็บหลักฐานซ้ำบนเครื่องที่ได้รับอนุญาต ไม่ควรเปลี่ยนแปลงกฎไฟร์วอลล์ระหว่างการเก็บภาพ เว้นแต่มีแผนและช่องทางกู้คืนที่ปลอดภัย และควรเก็บเอาต์พุตในช่วงเวลาเดียวกันเมื่อต้องการเปรียบเทียบลำดับของกฎ (rule order)

ข.1 สถานะบริการและพอร์ต

bash
sudo systemctl status nginx --no-pager
sudo systemctl status php8.3-fpm --no-pager
sudo systemctl status mysql --no-pager
sudo systemctl status fail2ban --no-pager
sudo ss -tulpn

ข.2 Nginx และใบรับรอง (Certificate)

bash
sudo nginx -t
sudo certbot certificates
sudo certbot renew --dry-run
curl -I http://papayapogpog.duckdns.org
curl -I https://papayapogpog.duckdns.org

ข.3 กฎความปลอดภัยของเครือข่าย (Network Security Rules)

bash
sudo iptables -S INPUT
sudo iptables -L INPUT -v -n --line-numbers
sudo ipset list thailand
sudo fail2ban-client status sshd
sudo sshd -T | grep -Ei 'permitrootlogin|passwordauthentication|pubkeyauthentication'

ข.4 การตรวจสอบ DNS จาก Windows PowerShell

powershell

nslookup papayapogpog.duckdns.org